03-apis

03 — APIs

Base URL (production): `https://ldapa-portal-production.up.railway.app` **Interactive docs (Swagger UI):** `https://ldapa-portal-production.up.railway.app/docs` **OpenAPI JSON:** `https://ldapa-portal-production.up.railway.app/openapi.json`

All request and response bodies are JSON. `Content-Type: application/json` unless noted (CSV upload uses `multipart/form-data`). All admin routes require a Bearer JWT in the `Authorization` header.

---

1. Conventions

1.1 Authentication

- **Public endpoints:** no auth.
- **Admin endpoints** (`/api/admin/*`): must include `Authorization: Bearer <jwt>` where `<jwt>` is the token returned by `POST /api/admin/login`.
- JWTs are signed HS256 with the backend's `JWT_SECRET` and expire after 24 hours.
- A missing or invalid token returns `401 {"detail": "Invalid or expired token"}`.

1.2 Error shape

Errors follow FastAPI's default format:

```
{ "detail": "Human-readable error" }
```

HTTP status codes used:

Code	Meaning
200	Success
401	Missing/invalid/expired auth token
404	Resource not found
422	Request body failed validation (Pydantic)
429	Rate limit exceeded (chat only)

1.3 Rate limiting

Only `POST /api/chat` is rate-limited: **30 requests per 60 seconds per session ID** (or per IP if no session ID). Exceeding it returns `429 {"detail": "Too many requests. Please try again later."}`.

---

2. Public Endpoints

2.1 `GET /api/health`

Health check for Railway/Vercel monitoring.

Response

```
{ "status": "ok" }
```

2.2 `POST /api/chat`

Send a chat message and receive an AI-generated response plus (optionally) a list of provider recommendations.

Request body

```
{
  "session_id": "b6a1d6ec-...",           // optional — omit on the first message
  "message": "I need a reading tutor in Pittsburgh for my 9-year-old",
  "history": [                             // full prior conversation (may be empty)
    { "role": "user",      "content": "..." },
    { "role": "assistant", "content": "..." }
  ]
}
```

Validation: - `message`: 1–5000 characters, required - `history[].content`: max 10,000 characters per message - `history[].role`: `"user"` or `"assistant"`

Response body

```
{
  "session_id": "b6a1d6ec-...",            // stable UUID for this conversation
  "response": "Thanks for sharing...\n\n[PROVIDERS]\n\n...",
  "providers": [                           // empty when no search ran
    {
      "id": "e2f...",
      "name": "Jane Doe",
      "profession_name": "Tutor",
      "services": "Reading, Math",
      "training": "Orton-Gillingham",
      "city": "Pittsburgh",
      "state_code": "PA",
      "zip_code": "15213",
      "price_per_visit": "$80 - $120",
      "sliding_scale": false,
      "insurance_accepted": "N/A",
      "age_range_served": "Ages 6-14",
      "phone": "412-555-0199",
      "email": "jane@example.com",
      "website": "https://janedoe-tutoring.example",
      "credentials": "Certified by ISSA",
      "listing_type": "Individual",
      "grades_offered": null
    }
  ],
  "escalate": false                        // true if a crisis was detected
}
```

The assistant text may contain a literal `[PROVIDERS]` token. The frontend strips that token and renders the `providers` array in its place as cards.

2.3 `POST /api/feedback`

Record a thumbs-up or thumbs-down on a specific assistant message.

Request body

```
{
  "message_id": "3c...",                   // ID of the assistant message (from
        chat transcript)
  "session_id": "b6a1d6ec-...",
  "rating": "positive"                     // or "negative"
}
```

Response body

```
{ "success": true }
```

Note: the API accepts `"positive"` / `"negative"`; they are stored in the database as `"up"` / `"down"` respectively.

---

3. Admin Endpoints — Authentication

3.1 `POST /api/admin/login`

Request body

```
{
  "email": "admin@ldapa.org",
  "password": "admin123"
}
```

Response body

```
{
  "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.....",
  "user": { "id": "admin1", "email": "admin@ldapa.org", "name": "LDA of PA Admin" }
}
```

Errors

- `401 {"detail": "Invalid credentials"}` — email unknown or password mismatch

The returned token is valid for 24 hours. The frontend stores it in `localStorage` and attaches it to every subsequent admin request.

---

4. Admin Endpoints — Dashboard

All endpoints below require `Authorization: Bearer <token>`.

4.1 `GET /api/admin/dashboard/stats?period=week`

Aggregate stats for the overview page.

Query params: - `period` — `today` | `week` | `month` | `all` (default: `week`) — filters which time window `chat_sessions` is counted over. Provider counts are always live (not period-scoped).

Response

```
{
  "total_providers": 3610,
  "verified": 0,
  "unverified": 3610,
  "archived": 0,
  "chat_sessions": 42,
  "avg_feedback": 4.3,
  "top_themes": ["reading evaluation", "dyslexia support", "school struggles",
        "finding providers", "affordable tutoring"]
}
```

`avg_feedback` is `up / total` ratio scaled to a 0–5 range. Themes are keyword-extracted from the last 50 user messages (see `_extract_themes` in `dashboard.py`).

4.2 `GET /api/admin/dashboard/chat-volume?period=week`

Time series for the chart on the overview page.

Query params: `period` — `week` (7 days, default) | `month` (30 days).

Response

```
{
  "data": [
    { "date": "2026-04-12", "count": 4 },
    { "date": "2026-04-13", "count": 7 },
    ...
  ]
}
```

4.3 `GET /api/admin/dashboard/recent-sessions?page=1&per_page=20`

Paginated list of chat sessions, newest first. Each session includes the average rating of its feedback events.

Response

```
{
  "sessions": [
    {
      "id": "b6a1d6ec-...",
      "started_at": "2026-04-18T14:02:11",
      "message_count": 8,
      "user_location": { "city": "Pittsburgh", "zip": "15213" },
      "escalated": false,
      "avg_rating": 4.0
    }
  ],
  "total": 42
}
```

4.4 `GET /api/admin/dashboard/sessions/{session_id}`

Full transcript of a single session including every message and every feedback event.

Response

```
{
  "session": {
    "id": "b6a1d6ec-...",
    "user_location": { "city": "Pittsburgh", "zip": "15213" },
    "started_at": "...",
    "last_message_at": "...",
    "message_count": 8,
    "escalated": 0
  },
  "messages": [
    { "id": "...", "session_id": "...", "role": "user",      "content": "...",
        "providers_shown": "[]", "created_at": "..." },
    { "id": "...", "session_id": "...", "role": "assistant", "content": "...",
        "providers_shown": "[\"e2f...\"]", "created_at": "..." }
  ],
  "feedback": [
    { "id": "...", "message_id": "...", "session_id": "...", "rating": "up",
        "created_at": "..." }
  ]
}
```

`providers_shown` is a JSON-encoded string containing the IDs of the provider cards that were rendered with that assistant message.

---

5. Admin Endpoints — Provider CRUD

5.1 `GET /api/admin/providers`

Paginated provider list with search + filters.

Query params:

Param	Type	Notes
`search`	string	matches `name`, `services`, or `training` (case-insensitive LIKE)
`status`	`verified` | `unverified` | `archived`	exact match on `verification_status`
`profession`	one of `Tutor`, `Health_Professional`, `Lawyer`, `School`, `Advocate`	case-insensitive
`city`	string	case-insensitive substring match
`page`	int	default 1
`per_page`	int	default 20

Soft-deleted rows (`is_deleted = 1`) are never returned.

Response

```
{
  "providers": [ { ...ProviderResponse... } ],
  "total": 3610,
  "page": 1,
  "per_page": 20
}
```

5.2 `GET /api/admin/providers/{provider_id}`

Full provider detail. Returns `404` if not found or soft-deleted.

Response: `ProviderResponse` (see §7).

5.3 `POST /api/admin/providers`

Create a new provider. Auto-generates `id` (UUID) and timestamps.

Request body: `ProviderCreate` (§7). Only `name` and `profession_name` are required.

Response: the created `ProviderResponse`.

5.4 `PUT /api/admin/providers/{provider_id}`

Update any subset of fields. Fields omitted (or set to `null` for nullable columns) are left unchanged. `updated_at` is set automatically.

Request body: `ProviderUpdate` (§7).

Response: the updated `ProviderResponse`.

5.5 `DELETE /api/admin/providers/{provider_id}`

Soft-delete — sets `is_deleted = 1`. The record is retained in the database and can be restored via direct SQL if needed.

Response

```
{ "success": true }
```

5.6 `PATCH /api/admin/providers/{provider_id}/verify`

Shortcut to mark a provider verified. Sets `verification_status = 'verified'` and `last_verified_at = now`.

Response: the updated `ProviderResponse`.

5.7 `PATCH /api/admin/providers/{provider_id}/archive`

Sets `verification_status = 'archived'`.

Response: the updated `ProviderResponse`.

5.8 `POST /api/admin/providers/bulk-verify`

Body: `{ "ids": ["uuid1", "uuid2", ...] }` — verifies all listed providers in a single request.

Response

```
{ "success": true, "count": 12 }
```

5.9 `POST /api/admin/providers/bulk-archive`

Same shape as bulk-verify but archives instead.

---

6. Admin Endpoints — CSV Import

6.1 `POST /api/admin/providers/import/preview`

`multipart/form-data` with a single file field `file` containing the Brilliant Directories export (UTF-8, optional BOM).

Parses and validates the CSV without writing to the database. Returns valid rows, row-level warnings, and fatal per-row errors.

Response

```
{
  "valid": [
    { "id": "<new-uuid>", "name": "Jane Doe", "profession_name": "Tutor", "...":
        "..." }
  ],
  "warnings": [
    "Row 42: Could not parse city from address 'PO Box 12'"
  ],
  "errors": [
    "Row 103: Missing profession_name"
  ]
}
```

The frontend shows this as a preview — the admin confirms before any insert happens.

6.2 `POST /api/admin/providers/import/confirm`

Body: `{ "providers": [ ...array of rows from the preview response... ] }`.

Inserts every row (no deduplication or upsert — callers are expected to only submit rows they want inserted). Each row gets a UUID if one was not supplied, plus `created_at` / `updated_at`.

Response

```
{ "imported": 1287, "skipped": 0 }
```

See **Doc 4 — Data Modeling** for the column mapping from Brilliant Directories CSV to database fields.

---

7. Schemas

7.1 `ProviderResponse` / `ProviderCreate` / `ProviderUpdate`

All three schemas share (roughly) the same fields. The differences: - `ProviderCreate`: `name` and `profession_name` required, everything else optional with defaults. - `ProviderUpdate`: every field is optional (partial updates). - `ProviderResponse`: every field present; includes `id`, `verification_status`, `last_verified_at`, `created_at`, `updated_at`.

Field	Type	Notes
`id`	string (UUID)	(response only)
`first_name`	string | null	
`last_name`	string | null	
`name`	string	computed “first last” on import but editable
`listing_type`	string | null	`Individual` or `Company`
`profession_name`	string	one of `Tutor`, `Health_Professional`, `Lawyer`, `School`, `Advocate`
`services`	string | null	free text, e.g. `"Therapist,Doctor=>Psychiatrist"`
`training`	string | null	e.g. `"Wilson Language"`, `"Orton-Gillingham"`
`credentials`	string | null	license numbers
`license`	string | null	license type
`address`	string | null	free-text street address
`city`	string | null	
`state`	string	default `"PA"`
`state_code`	string	default `"PA"`
`zip_code`	string | null	5-digit
`lat`, `lon`	number | null	used by geo search
`age_range_served`	string | null	free text, e.g. `"Adults, Teens"`
`grades_offered`	string | null	school-only, e.g. `"Grades 1-8"`
`price_per_visit`	string | null	e.g. `"$150 - $250"`
`sliding_scale`	boolean	default `false`
`insurance_accepted`	string | null	free text
`ld_adhd_specialty`	boolean	default `false`
`learning_difference_support`	boolean	default `false`
`adhd_support`	boolean	default `false`
`student_body_type`	string | null	school-only
`total_size`	string | null	school-only
`average_class_size`	string | null	school-only

Field	Type	Notes
`religion`	string | null	school-only
`phone`	string | null	
`email`	string | null	
`website`	string | null	
`profile_url`	string | null	link to Brilliant Directories listing
`staff_notes`	string | null	admin-only notes
`verification_status`	`unverified` | `verified` | `archived`	(response only; `ProviderUpdate` can change it)
`last_verified_at`	ISO timestamp | null	(response only)
`created_at`, `updated_at`	ISO timestamp	(response only)

7.2 `ProviderCard` (chat response subset)

Same fields as `ProviderResponse` minus admin metadata (no `verification_status`, no `last_verified_at`, no `staff_notes`, no `lat` / `lon`).

7.3 `ChatMessage`

```
{ "role": "user" | "assistant", "content": "string" }
```

7.4 `FeedbackRequest`

```
{
  "message_id": "uuid",
  "session_id": "uuid",
  "rating": "positive" | "negative"
}
```

---

8. CORS

The backend accepts cross-origin requests only from URLs listed in the `CORS_ORIGINS` environment variable (comma-separated). Current production value:

```
https://ldapa-public-portal.vercel.app,https://ldapa-admin-panel.vercel.app
```

If a custom domain is added (e.g. `portal.ldaofpa.org`), it must also be appended to `CORS_ORIGINS` in Railway and the backend will redeploy automatically.

---

9. Interactive API Explorer

FastAPI auto-generates a Swagger UI. Visit:

```
https://ldapa-portal-production.up.railway.app/docs
```

You can call every endpoint from the browser. For admin endpoints, click **Authorize** at the top and paste a Bearer token obtained from `/api/admin/login`.

---

10. Related Documents

- **01 — Technical Requirements and Design**
- **02 — System Architecture**
- **04 — Data Modeling & DB Population**
- **05 — Deployment**
- **06 — Handoff**